# Studio Nx

Backend(FastAPI/Python) 34 — POST /api/v1/auth/logout

2026-10-07

# Backend(FastAPI/Python) 34 — 라우터 `POST /api/v1/auth/logout`

| 항목 | 내용 |
|---|---|
| 파일 | `studionx/backend/app/api/v1/auth.py` (함수 이름 `logout`) |
| 작업 | P1-05 로그인 — 로그아웃 · PRD 01 FR-104 (P1-05 마지막) |
| 작성 | Claude (AI) · 2026-10-07 · 사용자 검토 |
| 이전 · 다음 | 33 `POST /auth/refresh` · (P1-05 끝) |

## 1. 하는 일

리프레시 쿠키를 **지우라는 응답**을 보낸다. 본문 없이 204.

```
POST /api/v1/auth/logout

→ 204 No Content
Set-Cookie: snx_refresh=""; expires=(지금); HttpOnly; Max-Age=0; Path=/api/v1/auth; SameSite=lax
```

| 토큰 | 로그아웃할 때 누가 지우나 |
|---|---|
| Refresh (쿠키) | **이 라우터** — JS 는 `HttpOnly` 쿠키를 지울 수 없어서 서버가 지워야 함 |
| Access (JS 메모리) | 화면 `logout()` 의 `clearAccessToken()` (JS 08) |

## 2. 언제 쓰나

헤더의 **Sign Out** 버튼 → JS 08 `logout()`.

| 순서 | 화면 · 서버 | 일어나는 일 |
|---|---|---|
| ① | `logout()` | `api.post('/auth/logout', undefined, { auth: false })` |
| ② | **이 라우터** | 204 + 쿠키 지우기 |
| ③ | `logout()` | `clearAccessToken()` → `home.html` 로 이동 |
| ④ | 다음에 사이트를 열면 | 쿠키가 없어 재발급(33) 401 → 로그인 안 된 상태 |

ai-note 34(P1-02 · 03 실제 사이트 시험) 에서 `/auth/logout → 500` 이었던 것이 이제 204 다. (그때도 `logout()` 은 실패를 무시하고 홈으로 갔지만, 쿠키는 남아 있었다.)

## 3. 코드

**import** (파일 맨 위 — 32 · 33 과 같음, 이번에 추가한 것 없음)

```
from fastapi import APIRouter, Cookie, Query, Response, status
…
```

이 함수는 **`Response`** · **`status`** 를 쓰고, 쿠키 지우기는 31 `clear_refresh_cookie()` 에 맡긴다.

**함수**

```
@router.post("/logout", status_code=status.HTTP_204_NO_CONTENT)
def logout(response: Response) -> None:
    clear_refresh_cookie(response)
```

### 문법 풀이

| import 문법 | 뜻 |
|---|---|
| `from fastapi import status` | 상태 번호에 이름을 붙인 모음 (`HTTP_204_NO_CONTENT` = 204) |

| 식 | 뜻 |
|---|---|
| `status_code=204` | 성공 · **본문 없음** |
| `-> None` | 돌려줄 본문이 없음 |
| `response: Response` | 여기에 붙인 쿠키 지우기 헤더가 204 응답에 실림 |
| `db` · `user` 인자가 없음 | 로그인 확인도, DB 도 쓰지 않음 |

## 4. 흐름

1. 31 로 "지금 만료" 쿠키를 응답에 붙인다.
2. 204 로 응답한다.

## 5. 왜 이렇게

| 선택 | 이유 |
|---|---|
| 로그인 확인 없이 받음 (템플릿 권장) | Access Token 이 이미 만료된 채로 Sign Out 을 눌러도 쿠키는 지워져야 한다. 하는 일이 "쿠키 지우기" 뿐이라 누가 불러도 위험이 없다 |
| 서버에 아무것도 기록하지 않음 | 토큰을 서버에 저장하지 않는 방식(JWT)이다. 남은 Access Token 은 최대 30분 뒤 스스로 만료된다 |
| 204 | 돌려줄 내용이 없다는 표준 응답. `api.js` 는 204 를 `null` 로 처리한다 (JS 02) |

**참고 — 쿠키를 훔쳐 간 경우:** 로그아웃은 **이 브라우저**의 쿠키만 지운다. 이미 복사해 간 리프레시 토큰은 3일 동안 유효하다. 이를 막으려면 서버에 "무효 토큰 목록" 을 두거나 비밀번호 변경 때 모든 토큰을 끊는 기능이 필요하다 — Phase 1 범위 밖이라 나중에 검토한다.

## 6. 시험 (`tests/test_auth_routes.py` 에 3개 추가 · 모두 43개, 실제 앱 + MySQL)

| 시험 | 확인한 것 |
|---|---|
| 로그인 → 로그아웃 → 재발급 | 로그아웃 전 재발급 200, 로그아웃 204 · 본문 없음 · `snx_refresh=""; Max-Age=0; Path=/api/v1/auth`, 로그아웃 뒤 재발급 401 |
| 로그인 안 한 상태 | 204 |
| 엉터리 `Authorization` 헤더 | 204 (로그인 확인을 하지 않음) |

전체 시험 234개 통과, `ruff` 검사 통과. 인증 파일(`auth.py` · `security.py` · `auth_service.py`)에 남은 `NotImplementedError` 0개.